

Laporan Bulan Agustus — SpringHub

Periode: 1 – 25 Agustus 2026 **Proyek:** SpringHub — Jaga Semesta (www.springhub.id) **Penyusun:** Ayatullah Reza — Full-stack Developer **Referensi:** LAPORAN-PASAR-BIBIT-DAN-BILLING.md (24 Juni–30 Juli)

Bagian 1 — Hardening, Staging & Modul Belajar (1-14 Agustus)

Ringkasan

Fokus: mengunci input, menutup XSS, menstabilkan staging agar produksi bisa diuji tanpa takut data hilang. Staging paralel di VPS (5433/6380/31760/8080) di-restore dari dump produksi dan diuji 205 test manual.

Input & XSS

Area	Detail
83 field lib/forms.ts	.max(500) (cerita 5000) — cegah payload raksasa
DOMPurify 2 lapis app/api/courses/[slug]/route.ts	jsdom tidak masuk bundle client (serverComponentsExternalPackages), <script>/onerror/javascript: bersih
Bug	lib/sanitize.ts syntax, await di luar async (queue-worker), nginx-staging server_name ~^(?<sub>[a-z0-9-]+)
Test	37/37 hijau (vitest), secrets scan bersih

Staging Paralel

- Stack docker-compose.staging.yml (DB springhub_staging 5433, Redis 6380, web 31760, nginx 8080 basic auth 181ff4f6c436d9a69f9dd12e)
- Restore backups/springhub-20260812-0513.dump , baseline 10 migrasi (migrate resolve --applied), fix-orphan-reports 0 klaster, health OK

Modul Belajar

- 461 halaman, 3.5MB MODUL-BELAJAR.pdf — 12 bab, 363 file ±48.500 baris, generator scripts/generate-modul-belajar.mjs (playwright, setTimeout 1500 biar tidak terpotong)

Audit Foto & Hardening (14 Agu, via staging)

Temuan	Perbaikan
Foto: Blob type kosong di Chrome Android, PHOTOS_PENDING drop, N+1 foto	QueueWorker serverReportId + retry per-siklus 30s, clientCorrelationId + uploadPhotoWithCsrf, foto admin sekaligus + badge ⚠️ 0 foto
PII bocor 3 rute	map-points/[id], projects/[id], seedlings/[id] → phone admin-only, approved filter
CSRF 14 route	verifyCsrfToken() ke photos/reports/projects/notifications/offline/courses/profile/admin
Lain	approve-all transaction, escapeHtml email, getClientIp, middleware api/admin/* + CSP unsafe-eval hapus

Bagian 2 — Security Hardening & Deploy Produksi (19-25 Agustus)

Ringkasan

Produksi di-patch CVE, CSRF di auth, dan data Epicollect diaktifkan. Semua dikerjakan **staging dulu, produksi setelah ACC** (sesuai instruksi 25 Agu).

Data Epicollect

- **199 report + 551 foto** (23×1 + 176×3) `public/form-1__*.json` → `clientCorrelationId = ec5_uuid`
- Staging: 199/199 approved, 189 spring active (total 261) — 23 report 1-foto via `ALLOW_LOW_PHOTO_APPROVE` sempat di-approve lalu **di-revert total** (route original)
- **Aktivasi 24-25 Agu (staging → produksi):** backup 12M/5.4M, `scripts/activate-staging-data.ts` approve 4 pending + aktifkan **8 data asli** (Sumber Telaga, Belik Soka, Sumber Gempol, Sumber Taman, Randu Alas 46 reports, Sumber Brantas, Sumber Maron, Mata Air Kalibayem) — skip 5 kosong + 24 dummy. Hasil: staging **261→269** active (160 groups), produksi **73→81** active (81 groups). Backfill `scripts/backfill-epicollect-photos.ts` dry-run **0 perlu** (551/551 sudah lengkap).

CVE & Auth

Area	Detail
CVE-2025-29927	Next 14.2.5→14.2.35 (lalu 15.5.23 di P1, next.config.mjs serverExternalPackages, 35 route params: Promise + await cookies())
CSRF auth	6 route + 5 halaman (sign-in/join/forgot/reset/logout) just-in-time <code>fetch("/api/csrf")</code>
Deps	sharp 0.34.5→0.35.3, jose 6.2.9, prisma 7.9.1, noeviction, image-worker redisConnectionFromUrl

P0-P2 Hardening (24-25 Agu, 26 temuan, 1 per 1)

P0 KRITIS — commit c7765a5 :

- DB prod ghost `_prisma_migrations` 20260603_add_comments NULL → hapus, buat `PasswordResetToken` + 3 index, `Donation.invoiceId ''` → `inv-*` + UNIQUE + 5 index, RLS 8 policy `Report / Profile`, `clientCorrelationId` manual→form 503 → 200
- Login `app/api/auth/login/route.ts:56` `lockout` enforce sebelum `bcrypt` → 429 + `resetAt`
- CSRF `lib/csrf.ts:33` `verifyJwtWithRotation` + `lib/auth.ts:8` hapus `const SECRET` cache
- Middleware `middleware.ts:56` `has("x-middleware-subrequest")`
- Secrets `.env.example:54` `REDIS_PASSWORD` → `CHANGE_ME_STRONG_RANDOM`

P1 HIGH — 71585ab , 7f3d2fb , c7ccc2d , ae68878 :

- PII hapus `email` `springs/[id]:72` & `projects/[id]:15`, leak `springs/bulk:33` tambah `status:"active"`
- Rate-limit 7 route → `dashboard`, `springs/[id]`, `gallery`, `map-points`, `seedlings`, `notifications` (POST admin-only), `user/profile`, `offline/session`, `courses`
- Next 15.5.23 (2 advisory DoS → 0)

P2 PWA — f97c726 , 497a40d , 66eb817 :

- `use-auto-save` `draftId` mismatch + interval reset, `BlobPreview` 5 file revoke leak, `site-header` `clearAllOfflineUserData`, `queue-worker` `MAX_RETRIES` 3→20, compose `DATABASE_URL` pool + `image:springhub-web`, `lib/sanitize.ts:10` `g` flag, `app/springs/[id]:494` alt foto.

Deploy Produksi 25 Agu

- `docker compose build web` Next 15 (124s) → `up -d web worker nginx` → Up 65s (healthy) 15.5.23
- Health `curl 31759/health` healthy, `curl /api/springs` 81 prod / 269 staging, form POST `/api/reports` 200 {success:true}

Manual Test

- 188→205 test (24 kategori, +17 Test 24 Full Data Flow submit→pending tidak muncul publik→approve→publik snapped tanpa PII→foto 200 →gallery→rate-limit 429 →CSRF 403 →export CSV) — MANUAL-TEST-FINAL.md:1 25 Agu

Bagian 3 — Kendala Tetap

Komponen	Status
Xendit	XENDIT_SECRET_KEY="" / XENDIT_WEBHOOK_TOKEN="" — backend invoice/webhook siap, butuh key dashboard
Cloudflare R2	S3_*= "" — fallback /data/uploads lokal via nginx alias, backup DB 03:00 harian, uploads belum harian
Sentry	NEXT_PUBLIC_SENTRY_DSN="" — error ke AppError DB
Data test	24 dummy pending + 5 spring kosong masih pending — menunggu instruksi hapus

Bagian 4 — Billing

Billing Infrastruktur (bulanan, Hostinger)

No	Layanan	Biaya
1	Hostinger KVM 4 (4 vCPU, 8GB RAM, 200GB NVMe) + domain free 1 tahun	Rp350.000 / bulan
2	Cloudflare (CDN, SSL, DNS)	Rp0
3	Cloudflare R2 (10GB pertama)	Rp0
4	Resend (3.000 email/bln)	Rp0
TOTAL INFRA / BULAN		Rp350.000

Dibayar langsung ke Hostinger (otomatis).

Billing Pengembangan — Periode 1-25 Agustus 2026

Item	Detail
Nama	Ayatullah Reza Chalid
Peran	Full-stack Developer SpringHub
Periode	1 - 25 Agustus 2026
Rincian	Lihat Bagian 1-2 di atas (staging, Modul Belajar 461 hal, audit foto & hardening, CVE & CSRF, aktivasi 8 springs staging+prod, P0-P2 26 temuan, Next 15.5.23, manual test 205, deploy prod)
Total	Rp3.000.000 (Tiga Juta Rupiah)
Bank	BANK BRI — 359001035332531 a.n. Ayatullah Reza Chalid

Nilai mengikuti Juli (24 Jun-30 Jul: Rp2.500.000 untuk refaktor 5 form v2.1 + 103 import) — Agustus lebih berat security & infra, disesuaikan +Rp500.000.

Terima kasih atas kerjasamanya. SpringHub — Jaga Semesta — www.springhub.id

Dibuat: 25 Agustus 2026 Oleh: Tim Teknis SpringHub